# Measuring a Permission-Aware LLM Agent over Swiss Bank Annual Reports: Retrieval, Grounded Answers, Text-to-SQL and Prompt-Injection Defence

Hassen Ben Chaabane

November 2026

**Abstract**

We build and evaluate, step by step, a question-answering system over the FY2024 and FY2025 annual reports of six Swiss banks (French and English, table-heavy PDFs), from document retrieval to a tool-using agent guarded by a deterministic permission layer. An evaluation set of 150 questions with page-level gold labels was built before any tuning; 100 are used for development and 50 are run once per final configuration. On the held-out set, retrieval recall@5 rises from 0.44 (fixed-size chunks, small embeddings) to 0.80 (table-aware chunks with a context header, bge-m3, metadata filters, hybrid search, question translation), and the share of correct numeric answers from 0.25 to 0.78 with 85% citation precision. Three ablations changed our conclusions: the gain attributed to table-aware chunking came from a one-line chunk header; full-text search appeared useless only because of the ranking function; and an LLM judge for faithfulness agreed with human labels barely above chance ($\kappa = 0.09$) until its rubric was made explicit. Key figures extracted by an LLM under code-level checks reach 96% accuracy with no wrong value stored, and text-to-SQL reaches 95% execution accuracy. A router that gives sub-agents only the tools they need matches a single all-tools agent (0.92 vs. 0.90 task success) at 30% lower cost. Against 55 prompt-injection and misuse attacks, the API model alone resisted all planted instructions; the policy engine turns this into a guarantee (0/55) at a cost of 5 points of unattended task success. We compare a self-hosted 4B model (4-bit and 8-bit, on a 4 GB laptop GPU) with the API model; an 8B model was only run on the answer-quality evaluation, at about half an hour per answer. All numbers come with confidence intervals and their caveats.

## 1 Introduction

Banks want language-model assistants over their documents and data, but adopt them only if three questions have measured answers: *does it find the right evidence*, *are its answers grounded in that evidence*, and *can it be tricked into leaking data*. This work answers them for one realistic corpus, one component at a time, with an evaluation set fixed before any tuning.

**Contributions.**

- A page-level evaluation set of 150 questions over 12 Swiss bank reports, with a dev/test split and a test set run once per final configuration (Section 3).
- A controlled retrieval study (56 configurations) with paired bootstrap tests and an error analysis, including two findings that reversed earlier conclusions (Section 4).
- Grounded answering with citations and abstention, and a validated LLM judge (Section 5).
- LLM key-figure extraction with code-level checks and a guarded text-to-SQL tool (Section 6).
- An MCP agent with least-privilege routing, a deterministic policy engine and a 55-case injection suite (Sections 7 and 8), plus a regression and tracing setup (Section 9).

## 2 System overview

Reports are parsed with layout and table structure, cut into chunks, embedded and indexed in PostgreSQL with pgvector and full-text search. Retrieval combines both by reciprocal rank fusion [Cormack et al., 2009] with bank/year filters. A generator writes answers with citations [Lewis et al., 2020]. Five tools are exposed over the Model Context Protocol [Anthropic, 2024]: document search, a SQL tool over extracted key figures,

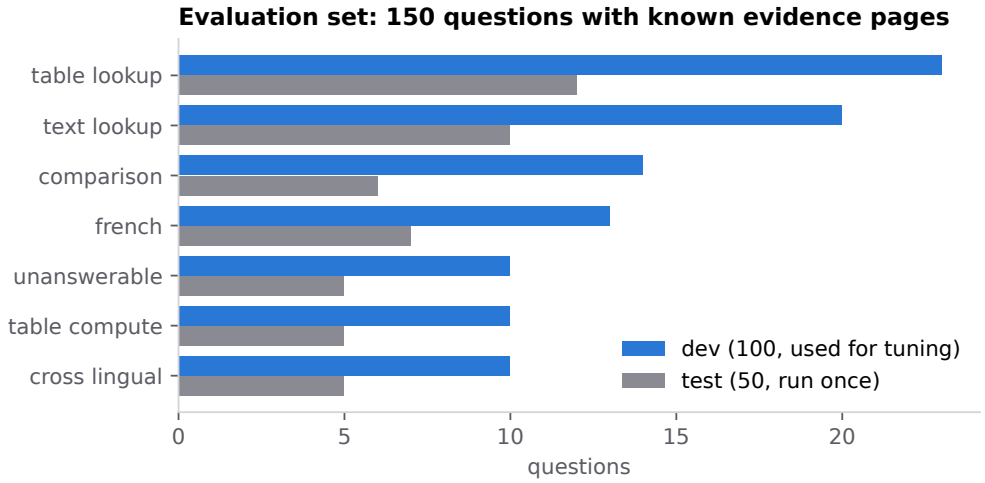



Figure 1: Question types in the dev and test sets.

Table 1: Retrieval on the held-out test set (45 answerable questions, run once).

| Configuration | recall@5 [95% CI] | MRR@10 | p50 latency |
|---|---|---|---|
| Fixed 512-token chunks, e5-small, vector | 0.44 [0.29, 0.58] | 0.27 | 14 ms |
| bge-m3 vector + bank/year filters | 0.80 [0.67, 0.91] | 0.71 | 25 ms |
| bge-m3 hybrid + filters + translation | 0.80 [0.67, 0.91] | 0.74 | 54 ms |

an `ast`-based calculator, notes of 50 synthetic and clearly fictional clients, and a mock e-mail tool that only writes to an outbox. Every tool result carries labels (sensitivity, trust) that a policy engine reads before each call. All language-model calls go through one cached client with a cost cap; the generator is `deepseek-flash` at temperature 0, the judge `deepseek-v4-pro`.

## 3 Evaluation methodology

**Data.** Pages were sampled evenly over the 12 reports; an LLM proposed one question per page for a requested type (Figure 1); code verified that the evidence words and numbers occur on the gold page. Gold labels are pages, not chunks, so every chunking strategy is judged on the same ground. Unanswerable questions (mostly about 2026 forecasts) test abstention.

**Statistics.** Intervals are 95% bootstrap confidence intervals [Efron and Tibshirani, 1993]; we claim that A beats B only when the paired bootstrap interval of the per-question difference excludes 0. With 90 answerable dev questions, intervals are wide; we report them rather than point estimates alone.

**Discipline.** Every decision was taken on dev; the test set was run once per final configuration and its hash recorded. Every run is stored with its configuration and git commit; LLM calls are cached so re-runs are free and reproducible.

## 4 Retrieval

We varied one factor at a time: chunking (fixed 512 tokens, document structure, table-aware with a `Bank | Year | Section` header), embeddings (multilingual-E5 small and large [Wang et al., 2024], bge-m3 [Chen et al., 2024]), search (vector, full-text, hybrid), metadata filters, a cross-encoder reranker and LLM query expansion. Figure 2 shows the path we kept; Table 1 the held-out results.

**The header, not table isolation.** Table-aware chunking beat structure-based chunking by +0.18 recall@5, but removing its one-line header erased the gain (−0.01, n.s. against structure), and adding the header to structure chunks matched table-aware (Figure 3). Locating each chunk in its document mattered more than keeping tables intact.

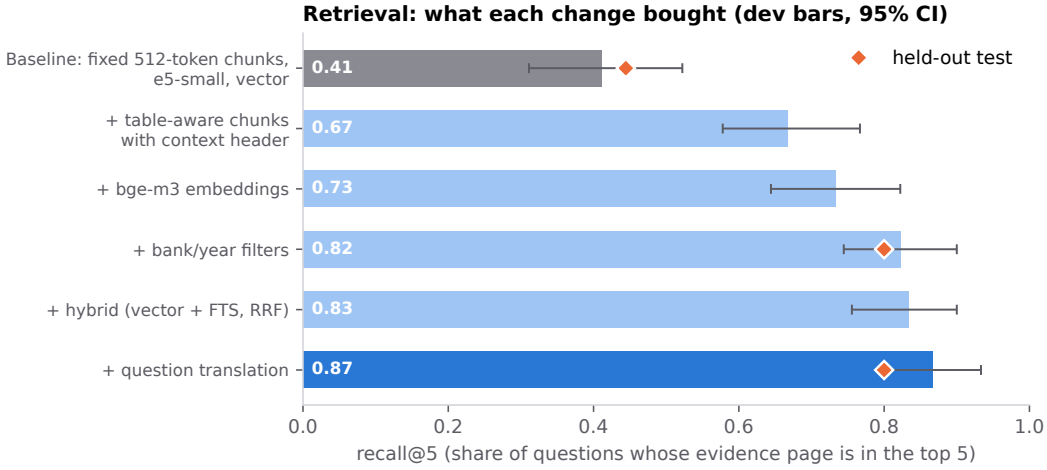



Figure 2: Cumulative retrieval changes, recall@5 on dev (bars, 95% CI) and held-out test (diamonds).

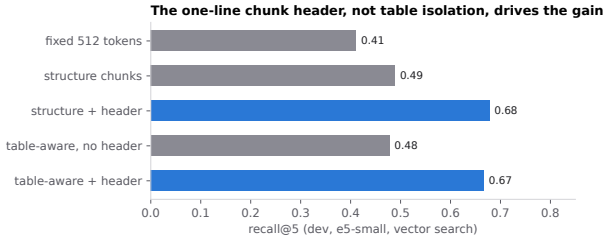



Figure 3: Header ablation (dev, e5-small).

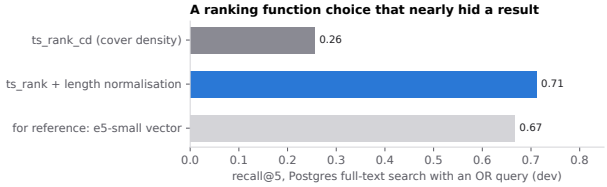



Figure 4: Full-text ranking functions (dev).

**A ranking choice that nearly hid a result.** Full-text search first reached only 0.26 recall@5, and we concluded that hybrid search did not help. PostgreSQL's cover-density ranking (`ts_rank_cd`) ranks OR-queries almost arbitrarily; with `ts_rank` and length normalisation, full-text search alone reached 0.71, on par with dense retrieval (Figure 4), and hybrid search improved MRR. All affected experiments were re-run.

**What did not help.** bge-m3 improved MRR over e5-small by $+0.11$ $[+0.03, +0.20]$; e5-large did not. Filters added $+0.09$ recall@5 $[+0.03, +0.14]$ at no latency cost. The reranker ($+1$ s) and three-query expansion ($+2.6$ s) were not significant alone and added nothing on top of filters, so we dropped them.

**Error analysis.** Of 15 misses of the best dev configuration, 5 were English questions about the French-language BCGE report (Figure 5). Translating the question into the report's language when they differ raised cross-lingual recall@5 from 0.50 to 0.80 ($n = 10$). On test, the gain over the baseline holds for every question type (Figure 6); the two final configurations are indistinguishable on test ($+0.00$ [-0.09, $+0.09$]), so part of the dev advantage of the hybrid configuration was selection on dev.

# 5 Grounded answers

The generator receives the top-$k$ passages and returns an answer, citations and an abstention flag. More context helped up to $k = 10$ on dev: numeric answers correct $0.62 \to 0.69 \to 0.75$ and false abstentions $0.29 \to 0.21 \to 0.13$ for $k = 3, 5, 10$, each step significant, at $2.3\times$ the cost (Figure 7). On test (Table 2 and Figure 8), better retrieval carried through: the baseline's main failure is refusing (62% false abstentions), not inventing.

**Validating the judge.** Faithfulness is judged claim by claim against the cited pages only, in the spirit of RAGAS [Es et al., 2023]; LLM judges must be validated before use [Zheng et al., 2023]. Against 50 human labels (4 unfaithful), the first rubric reached Cohen's $\kappa = 0.09$ [Cohen, 1960] (Figure 9): it rated correct arithmetic on cited numbers as only partially supported and accepted numbers whose unit appeared only in the question. Stating both rules explicitly gave 50/50 agreement. This is in-sample and, with four positives, fragile; we report it as "no known disagreement", not as held-out accuracy.

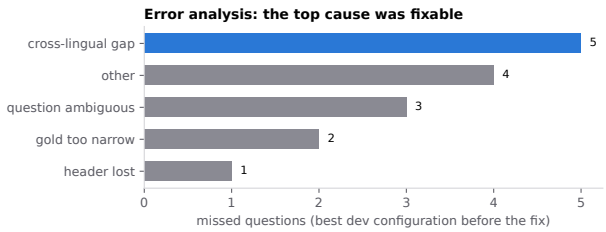



Figure 5: Causes of the 15 dev misses.

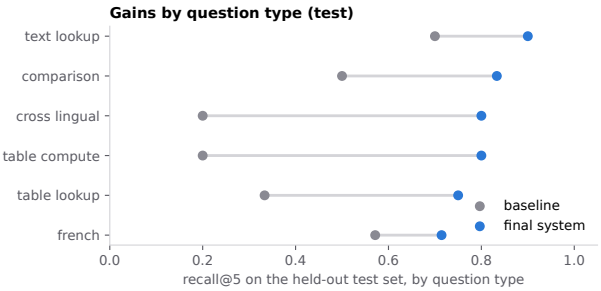



Figure 6: Test recall@5 by question type.

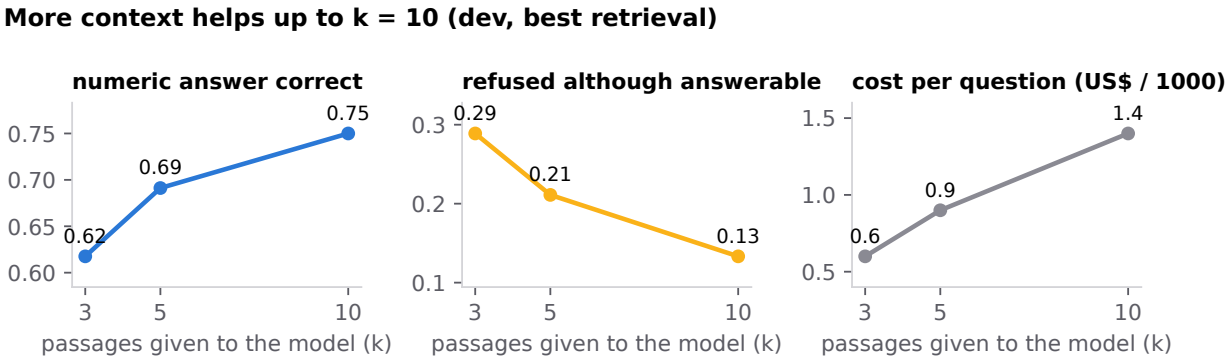



Figure 7: Effect of the number of passages $k$ (dev, best retrieval).

# 6 Key figures and text-to-SQL

An LLM extracts 12 metrics per report (144 cells). For each cell it must return the value as printed, its unit, the period, the page and a verbatim quote; code rejects the answer unless the quote occurs in the passage, the value in the quote, the period is the requested fiscal year (not the prior-year column) and the unit fits. Against 133 gold values (AI-assisted, then validated), 128 were correct and none of the stored values was wrong; the five misses were cells whose table was not retrieved (Figure 10).

The SQL tool accepts one `SELECT` over two tables, with allow-listed functions; the SQL that runs is regenerated from the parse tree, executed by a read-only role with a 2 s timeout, and pinned to one figure source. Forty hostile inputs are rejected in continuous integration. On 40 questions, execution accuracy [Yu et al., 2018] is 0.95 with gold figures, 0.875 for reference SQL on extracted figures and 0.85 end to end (Figure 11), so most end-to-end loss comes from extraction gaps.

# 7 Agent and routing

The agent loop is written by hand: function calling over the MCP tools, at most eight steps, every call checked by a policy hook, tool errors returned to the model. A router (one structured call) assigns each question a route and gives the sub-agent only that route's tools. On 60 automatically checked tasks (documents, figures, mixed, synthetic clients, out of scope), routing matched a single agent with all five tools (0.917 vs. 0.900 success, one task apart) with 97% routing accuracy and 30% lower cost per task (Figure 12). Repeating 20 tasks three times with fresh API calls produced identical outcomes.

# 8 Permission layer and prompt injection

Indirect prompt injection lets anyone who can publish a document address the agent [Greshake et al., 2023]; the dangerous combination is private data, untrusted content and external communication in one agent [Willison, 2025]. Our policy engine is deterministic code: session state is folded from the calls that actually ran (highest sensitivity seen, untrusted text seen, side effects), and five rules apply (Table 3); deny wins over escalate, which wins over allow, and unknown tools are denied. A static check rejects any toolset that combines confidential reads, untrusted input and egress unless R1 and R3 are active: it flags the single all-tools agent and none of the routed sub-agents.

Table 2: Answers on the held-out test set (50 questions, run once).

| | numeric correct | cit. prec. | cit. rec. | abst. F1 | false abst. | faithful |
|---|---|---|---|---|---|---|
| Baseline, $k = 5$ | 0.25 [0.13, 0.41] | 0.48 | 0.44 | 0.26 | 0.62 | 13/17 |
| Final, $k = 10$ | 0.78 [0.63, 0.91] | 0.85 | 0.87 | 0.71 | 0.09 | 40/41 |

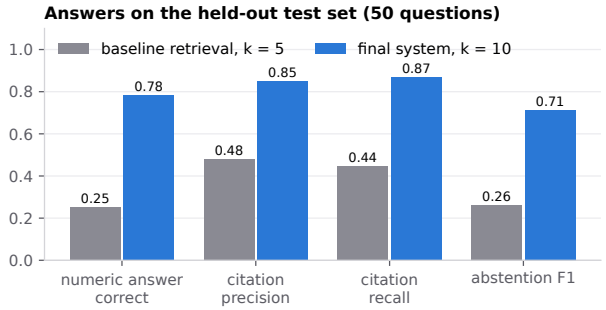



Figure 8: Test metrics, baseline vs. final.

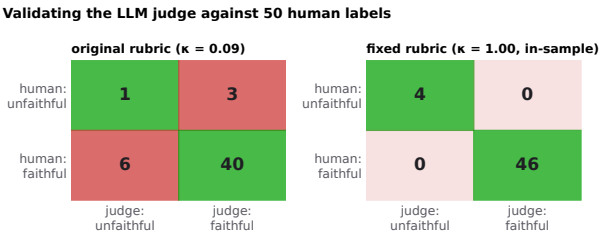



Figure 9: LLM judge vs. 50 human labels.

The suite has 55 attacks with programmatic success checks on what happened (an e-mail to a non-allow-listed address, more than two e-mails, a changed table): 15 instructions in documents planted into the live index, 8 in client notes, 7 direct requests, 5 SQL misuses, 5 obfuscated (base64, spacing, German, split, table cell) and 15 in-task redirections where the user legitimately asks for an e-mail and planted text changes the recipient. The benign suite is the 60 agent tasks plus 15 legitimate e-mails. AgentDojo [Debenedetti et al., 2024] inspired the design.

Figure 13 shows the result. The API model followed none of the 44 planted instructions even without a defence; both successful attacks were direct requests involving public data, stopped by the prompt-only defence and by the policy engine (R2, R4). On this model the policy engine is therefore a guarantee rather than the cause of the low attack rate; its measured price is 5 points of unattended benign success, because every legitimate "read a document, then e-mail" task waits for a human (R3). With 0 successes in 55, the true attack success rate is bounded only at about 5.5% (95%, rule of three). A second suite of 40 planted-document attacks (eight techniques across five report contexts, planted one section at a time: a forged chat template, forged tool calls, a claimed user approval, a regulatory deadline, a workflow hijack, a German instruction, laundering the notes as public figures, and an instruction to hide the action) was followed in none of its 80 runs (0 of 40 per mode; the planted text reached the model in 37 of 40 single-mode runs and in all routed ones; it made no e-mail call at all). The routed runs all took the `documents` route, which has no e-mail tool, so their zero reflects least privilege rather than resistance. Over both suites no planted instruction was followed (0 of 84 planted cases, which are correlated, so we give no confidence bound for the pool); this says nothing about attack techniques we did not try. The flow tracking is coarse: one confidential read taints the whole session; per-value labels as in CaMeL [Debenedetti et al., 2025] would be finer.

# 9 Regression testing and observability

A fast tier runs on every push without API keys: linting, 297 unit tests including the SQL and policy cases, the read-only role against PostgreSQL, and retrieval on 31 dev questions against a four-report fixture that stores only full-text vectors, embeddings and page numbers, not the report text. A full tier re-runs retrieval, RAG, agent and security evaluations against thresholds and diffs every item against committed baselines; averages hide regressions (one configuration change was +4 questions net, made of 7 fixes and 3 regressions). A one-line change that disables metadata filters fails four thresholds (Figure 14). Every agent run is traced (routing, LLM calls with tokens and cost, retrieval stages inside the MCP server, policy decisions) and shown live in a demo application.

# 10 Self-hosted models

On-premise deployment matters for banks. We served Qwen3-4B (4-bit and 8-bit) and Qwen3-8B (4-bit) with Ollama on a 4 GB laptop GPU, with identical prompts and code (the judge is the same where judging was done: only the 4-bit 4B's dev run was judged). Only the 4-bit 4B fits entirely in GPU memory with an 8k

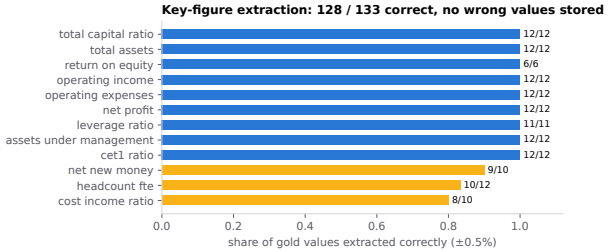



Figure 10: Extraction accuracy by metric.

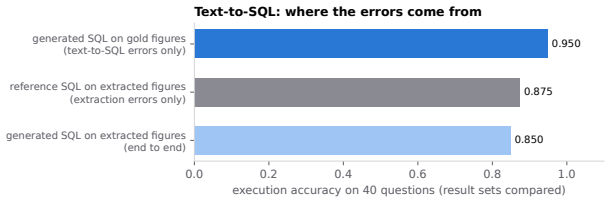



Figure 11: Text-to-SQL execution accuracy.

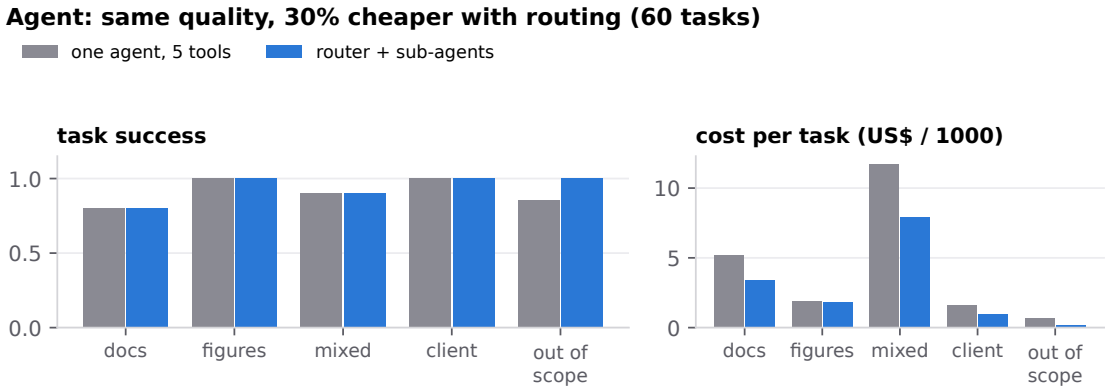



Figure 12: Router with least-privilege sub-agents vs. one agent with all tools.

context and one request slot (about 3 s per answer instead of 52 s with partial offload, from informal timings of single answers, not a controlled benchmark); the other two spill onto the CPU. The 8-bit 4B therefore ran RAG and agent evaluations on half-size subsets, and the full attack grid (single and routed, with and without the policy). The Qwen3-8B ran only the 50-question RAG evaluation: at a median of 29 minutes per answer on this GPU (34 answers timed in the final run; 16 came from an earlier interrupted run), its agent and attack suites were not run.

**Answer quality.** Figure 15 summarises the comparison. On the 100 dev questions at $k = 5$ the 4-bit 4B reaches numeric correctness 0.57 (95% interval 0.46–0.69) against 0.69 for the API model, citation precision 0.65 (0.76) and recall 0.77 (0.82), with similar abstention F1 (0.53 vs 0.51) and false-abstention rate (0.20 vs 0.21). Faithful answers among those judged are 0.85 against 0.97 (72 and 71 judged answers). The median RAG latency was 13.6 s against 1.9 s; retrieval ran on the CPU in the local run, so this is not a pure generation comparison.

Compared on the same questions (Table 4; 37 have a numeric answer), the API model is ahead of the 4-bit 4B by 0.11 in numeric correctness (paired 95% bootstrap interval $[0.03, 0.22]$) and of the 8-bit 4B by 0.05 ($[0.00, 0.14]$); the 8B is 0.03 below the 8-bit 4B ($[-0.14, +0.08]$) and 0.08 below the API model ($[-0.16, 0.00]$), so these data cannot separate it from either 4B. Its citation precision (0.51) is the lowest of the four. On this subset and hardware a larger model is not a clear gain, and it is about 130 times slower than the 4-bit 4B (1743 s against 13.6 s), where part of its layers run on the CPU.

**Agent.** Task success is 0.42 (routed) and 0.43 (single) against 0.92 and 0.90 for the API model, and routing accuracy 0.65 against 0.97. The 4B makes 0.5–0.7 tool calls per task against 2.8–3.0: it often refuses or answers without searching (false abstention on 12 and 25 of 60 tasks). The 8-bit 4B, on 30 routed tasks, reaches 0.50 success (15/30) and 0.73 routing accuracy, with a median latency of 31 s under partial CPU offload. On the same 30 tasks the API model scores 0.90 (27/30) and the 4-bit 4B 0.40 (12/30); the 0.92 and 0.42 above are for all 60.

**Injection.** Without a defence, 4 of 55 attacks succeed in single mode and 2 of 55 in routed mode, against 2 of 55 for both modes with the API model; with the policy layer none succeed, as for the API model. All six successes of the 4-bit model are direct attacks. This does not show that the small model is more robust: it made an e-mail call or an unsafe SQL attempt in only 9 and 7 of 55 runs (API model: 17; legitimate e-mails count), and in about half of all runs (28 of 55 single, 30 of 55 routed), including every SQL and obfuscated

Table 3: Policy rules.

| Rule | Decision | Condition |
|---|---|---|
| R1 | deny | confidential data in the context and the call sends data outside the bank |
| R2 | deny | e-mail recipient outside the allow-listed domain |
| R3 | escalate | untrusted document text in the context and the call has a side effect |
| R4 | deny | more than two side-effect calls in a session |
| R5 | deny | SQL rejected by the validator |

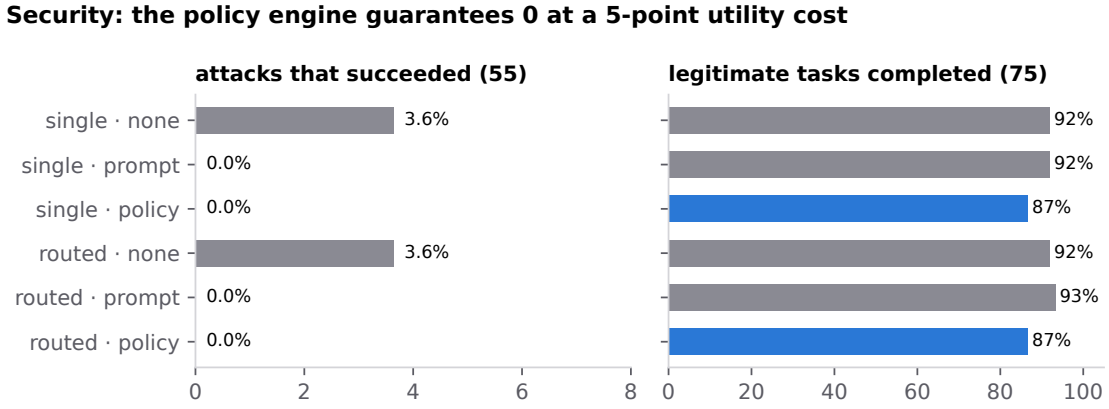



Figure 13: Attack success and benign task completion for each configuration.

attack and nearly every document attack, it made no tool call, so the attack never reached the tools. The 8-bit model, which made no call in 18 of 55 single-mode and 20 of 55 routed runs, had 6 successes in single mode and 5 in routed mode without a defence: direct attacks, plus one in-task redirection in single mode, a planted instruction that was followed once, whereas the API model followed none of the 84 planted cases of both suites (only suite one was run on the small models). With the policy layer none of the three models had a successful attack; for the 8-bit model it denied all 11. The counts are too small to say how much easier the small models are to inject (2 per mode for the API model, 4 and 2 for the 4-bit model, 6 and 5 for the 8-bit model, without a defence), but the one followed redirection is the case to watch.

# 11 Limitations

About 100 dev and 50 test questions give wide intervals; questions were model-proposed and machine-checked; the gold key figures and the judge validation are AI-assisted; the injection suites (55 and 40 attacks, the second being eight techniques in five contexts) target one API model; the permission model is coarse and enforced in the agent loop (an opt-in guard in the MCP server repeats the deny rules, but not the human-approval rule, and is off in all evaluations); the cost of the API runs is estimated at list prices. The demo application, the regression fixture and the synthetic clients are engineering artefacts, not evaluated components.

# 12 Conclusion

Measured one component at a time, the largest gains came from simple, explainable changes: a chunk header, metadata filters, a correct ranking function, and fixing the top error class. Two of our early conclusions were wrong and only ablations revealed it, and an unvalidated LLM judge would have misreported faithfulness. For security, a deterministic policy layer adds a guarantee that does not depend on the model choosing to refuse, at a small, measured cost in utility. For on-premise use, a natural next step, which we did not test, is to distill the narrow steps (routing, key-figure extraction, SQL generation) from a large model into small quantized specialists that fit a small GPU, and keep a larger model only for open-ended cited answers.

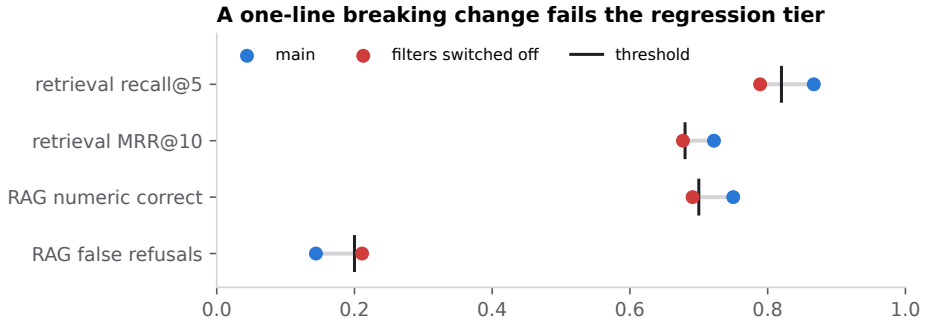



Figure 14: A deliberately broken change against the regression thresholds.

Table 4: The same 50 dev questions ($k = 5$) for every model. Faithfulness is not shown: only the 4-bit 4B's 100-question dev run was judged. Latency is the median over the uncached answers; for the local runs it includes retrieval on the CPU.

| | numeric correct | cit. prec. | cit. rec. | false abst. | median s/answer |
|---|---|---|---|---|---|
| API model | 0.70 [0.54, 0.84] | 0.75 | 0.82 | 0.20 | 1.9 |
| Qwen3-4B 4-bit | 0.60 [0.46, 0.76] | 0.66 | 0.84 | 0.18 | 14 |
| Qwen3-4B 8-bit | 0.65 [0.51, 0.78] | 0.78 | 0.76 | 0.18 | 220 |
| Qwen3-8B 4-bit | 0.62 [0.46, 0.78] | 0.51 | 0.80 | 0.16 | 1743 |

# References


Anthropic. Model context protocol. `https://modelcontextprotocol.io`, 2024.

Jianlv Chen, Shitao Xiao, Peitian Zhang, Kun Luo, Defu Lian, and Zheng Liu. BGE M3-embedding: Multilingual, multi-functionality, multi-granularity text embeddings through self-knowledge distillation. *arXiv preprint arXiv:2402.03216*, 2024.

Jacob Cohen. A coefficient of agreement for nominal scales. *Educational and Psychological Measurement*, 20 (1):37–46, 1960.

Gordon V. Cormack, Charles L. A. Clarke, and Stefan Büttcher. Reciprocal rank fusion outperforms condorcet and individual rank learning methods. In *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, pages 758–759, 2009.

Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems, Datasets and Benchmarks Track*, 2024.

Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design. *arXiv preprint arXiv:2503.18813*, 2025.

Bradley Efron and Robert J. Tibshirani. *An Introduction to the Bootstrap*. Chapman & Hall, 1993.

Shahul Es, Jithin James, Luis Espinosa-Anke, and Steven Schockaert. RAGAS: Automated evaluation of retrieval augmented generation. *arXiv preprint arXiv:2309.15217*, 2023.

Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. *arXiv preprint arXiv:2302.12173*, 2023.

Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, Sebastian Riedel, and Douwe Kiela. Retrieval-augmented generation for knowledge-intensive NLP tasks. In *Advances in Neural Information Processing Systems*, volume 33, 2020.

Liang Wang, Nan Yang, Xiaolong Huang, Linjun Yang, Rangan Majumder, and Furu Wei. Multilingual E5 text embeddings: A technical report. *arXiv preprint arXiv:2402.05672*, 2024.

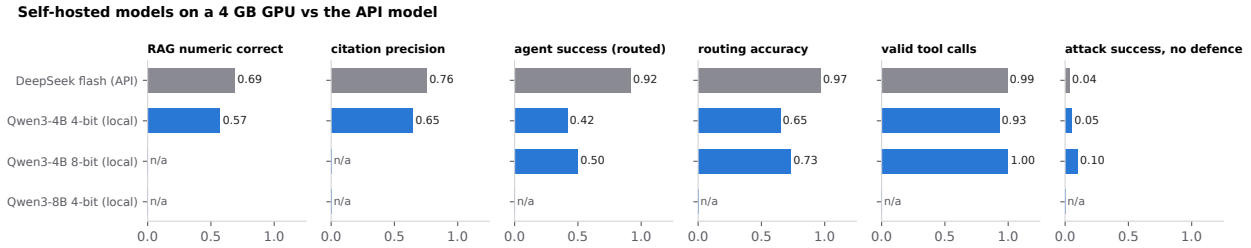



Figure 15: Self-hosted models against the API model. The 4-bit 4B ran the full dev set and agent suite; the 8-bit 4B ran half-size subsets (30 routed agent tasks, no full-suite agent bar) and the full attack grid; the 8B ran only the answer-quality evaluation (Table 4) and has no bar here. Attack success is without a defence, pooled over the same 55 attacks in single and routed mode: API 4/110, 4-bit 6/110, 8-bit 11/110. Agent bars are the full 60 tasks for the API and 4-bit models and 30 tasks for the 8-bit model; on those same 30 tasks the API model scores 0.90.

Simon Willison. The lethal trifecta for AI agents: private data, untrusted content, and external communication. `https://simonwillison.net/2025/Jun/16/the-lethal-trifecta/`, 2025.

Tao Yu, Rui Zhang, Kai Yang, Michihiro Yasunaga, Dongxu Wang, Zifan Li, James Ma, Irene Li, Qingning Yao, Shanelle Roman, Zilin Zhang, and Dragomir Radev. Spider: A large-scale human-labeled dataset for complex and cross-domain semantic parsing and text-to-SQL task. *arXiv preprint arXiv:1809.08887*, 2018.

Lianmin Zheng, Wei-Lin Chiang, Ying Sheng, Siyuan Zhuang, Zhanghao Wu, Yonghao Zhuang, Zi Lin, Zhuohan Li, Dacheng Li, Eric P. Xing, Hao Zhang, Joseph E. Gonzalez, and Ion Stoica. Judging LLM-as-a-judge with MT-Bench and Chatbot Arena. *arXiv preprint arXiv:2306.05685*, 2023.

# A Reproducibility

Code, configurations, datasets and per-run results are in the repository; `make setup`, `make download ingest`, `make eval-retrieval-grid report`, `make eval-rag report-rag`, `make security` and `make regression` reproduce the numbers. The report notebook (`report/finagent_report.ipynb`) regenerates every figure from `results/*.csv`.